Phishing Email analysis Final CheckList – Playbook V2

🧭 STEP 0 — Case Creation & Evidence Preservation

Goal: Don't lose evidence.

- Create incident ticket
- Ask user to **forward the email as attachment (.eml / .msg)** (not screenshot)
- Record:
  - Reporter name
  - Time received
  - Whether user clicked / entered creds / downloaded file

📩 STEP 1 — Email Header Analysis (Root Truth)

Tools:

- Microsoft Message Header Analyzer
- MXToolbox Email Header Analyzer
- Email Header plugin for Sublime Text
- IANA

Checklist

- Extract headers from .eml
- Identify:
  - Real sender IP (Received chain)
  - SPF / DKIM / DMARC result
  - Reply-To mismatch
  - Return-Path mismatch
  - Suspicious mail servers

👉 If SPF/DKIM fail → **Spoofed email**

🌐 STEP 2 — Domain & Sender Infrastructure Check

Tools:

- DomainTools Whois
- dnstwist
- dnstwister.report
- dnstwist.it

Checklist

- Check domain age (new = suspicious)
- Check registrar, country
- Run dnstwist on legit domain to see lookalikes
- Detect typosquatting / homoglyph domains

🔗 STEP 3 — URL Investigation (Most Important)

Tools:

- Unshorten.It
- urlscan.io
- VirusTotal
- URLVoid
- Google Safe Browsing Transparency Report
- URLhaus
- PhishTank
- url2png
- Wannabrowser

Checklist

- Unshorten URL
- Scan in urlscan + VT
- Check if phishing kit page loads (screenshot)
- Check hosting IP reputation
- Check if URL already reported in PhishTank/URLhaus

🧪 STEP 4 — Attachment Analysis (If present)

For .eml / .msg parsing

- emldump.py
- Email IOC Extractor

For Office docs / OLE

- oledump.py

For PDF

- pdfid.py
- pdf-parser.py

Sandbox detonation

- Hybrid Analysis
- ANY.RUN
- Joe Sandbox

Checklist

- Extract IOCs from attachment
- Check for macros / OLE streams
- Detect CVE patterns (e.g., CVE-2017-0199 HTA)
- Detonate safely in sandbox

🧬 STEP 5 — Payload / Encoding / Obfuscation

Tool:

- CyberChef

Checklist

- Decode Base64 / Hex / URL encoding
- Extract hidden URLs / scripts
- Analyze obfuscated JS / PowerShell

🧠 STEP 6 — Threat Intel Correlation

Tools:

- Cisco Talos
- VirusTotal
- PhishTank
- URLhaus

Checklist

- Check IP, domain, hash reputation
- See previous campaigns
- Identify phishing kit reuse

🏢 STEP 7 — Internal Impact Analysis (Microsoft 365)

Tools:

- Microsoft Exchange Message Trace
- Microsoft Purview eDiscovery Content Search

Checklist

- Who else received this email?
- Did anyone click?
- Search entire tenant for same subject / sender

- Pull all copies and quarantine

🚨 **STEP 8 — Containment Actions**

- Block sender domain/IP on email gateway
- Block URL on firewall / proxy
- Reset passwords for affected users
- Revoke sessions (if creds entered)
- Remove emails from all mailboxes

📄 **STEP 9 — Documentation (Very Important for SOC)**

Document:

- Attack type (BEC / Credential harvest / Malware)
- Sender infra
- IOCs (IPs, domains, hashes, URLs)
- User impact
- Actions taken
- Recommendations

🧪 **STEP 10 — Learn From Real Cases**

Study patterns from:

- Colonial Pipeline phishing entry vector
- Ubiquiti Networks BEC loss
- Ukraine power grid hack spear-phishing entry

🧠 **Golden Rule Flow (Remember This)**

Header → Domain → URL → Attachment → Intel → Internal Search → Containment → Report